Vasihat Nama: Secure Digital Legacy & Inheritance

System Architecture & Security Design Specification

---

1. Vision & Purpose

Vasihat Nama is a **Secure Digital Vault** designed to solve the critical problem of lost digital assets after a user's passing. It combines **Zero-Knowledge Encryption** with an automated **Dead Man's Switch (Legacy Protocol)** to ensure that encrypted information (passwords, documents, notes, financial data) is securely transferred to trusted nominees ONLY when the user is no longer able to check in.

---

2. High-Level Architecture

The system follows a modern **Serverless-First** approach:

- **Frontend (Flutter Mobile App):**
  - Cross-platform (iOS/Android) for universal accessibility.
  - Performs all heavy encryption/decryption on the client side.
  - Integrates Google ML Kit for on-device OCR and document intelligence.
- **Backend (Node.js/TypeScript):**
  - Hosted on **Vercel** for high availability and low latency.
  - Acts as a secure coordinator and storage manager (Stateless API).
  - Manages the **Heartbeat Logic** and **Legacy Protocol** triggers.
- **Database (PostgreSQL - Neon DB):**
  - Relational storage for metadata, nominee relationships, and system logs.
  - Encrypted at rest by the provider.
- **Storage (AWS S3):**
  - Binary object storage for encrypted documents.
  - Accessible only via temporary, authenticated **Presigned URLs**.

---

3. Security Architecture: The Zero-Knowledge Model

Security is built on the principle that **the server never knows the user's secrets**.

A. Key Management

1. **RSA-2048 Key Pair:** Every user generates a unique RSA key pair on their device during registration.
2. **Master Password:** The user provides a Master Password that is never sent to the server.
3. **AES-256 Wrapper:** The RSA Private Key is encrypted with a key derived from the Master Password (AES-256) before being backed up to the server.
4. **Hardware Storage:** Public/Private keys used for the current session are stored in the device's **Flutter Secure Storage** (Keychain for iOS, Keystore for Android).

B. Encryption Flow (Vault Items)

- **Encryption:** When a user adds a password or file, the app generates a unique **AES-256 session key**. The data is encrypted with this key. The session key itself is then encrypted with the user's RSA Public Key.
- **Data at Rest:** Only the encrypted content and the "wrapped" key are stored on S3/Neon.

- **Decryption:** To view an item, the app retrieves the wrapped key, decrypts it using the local RSA Private Key, and then decrypts the data.

---

4. Data Flow: Creating an Encrypted Item

1. **User Input:** User enters credit card info or selects a document.
2. **Local Process:**
    - App scans/extracts text using ML Kit.
    - App generates a one-time AES key.
    - Data is encrypted on-device.
3. **Secure Upload:**
    - App requests a **Presigned URL** from the backend.
    - App uploads the *encrypted* file directly to AWS S3.
    - No raw data ever touches the application server.
4. **Integrity Check:** Backend logs the file metadata after the upload is confirmed.

---

5. The Legacy Protocol (Inheritance Logic)

This is the core "Vasihat" (Will) functionality:

1. **Heartbeat Check-In:** The user must "check-in" to the app periodically (e.g., every 30 days).
2. **Trigger Mechanism:** If a user misses their check-in cycle, the backend system initiates the **Dead Man's Switch**.
3. **Verification:** The system sends multiple SMS/Email alerts to the user before proceeding.
4. **Nominee Activation:** Once the protocol triggers, the **Access Granted** flag is set to `true` for assigned nominees.
5. **Key Transfer:** Encrypted keys are re-wrapped for the nominee's public key (using the nominee's public key stored in the system), allowing them to decrypt the legacy data.

---

6. AI & Intelligent Features

- **Smart Scan:** Uses Google ML Kit to detect card numbers, expiry dates, and document types automatically.
- **Regional Compliance:** GPT-3.5 Turbo generates legal document checklists based on the user's country laws (e.g., India, UAE, USA).
- **Tone Analysis:** AI analyzes the emotional tone of final "Letter to Nominee" messages to ensure they are empathetic and clear.
- **AI Will Drafter:** Assists users in structuring their "Digital Will" with legal-best-practice suggestions.

---

7. Technical Stack

Layer	Technology
Mobile	Flutter / Dart
Backend	Node.js (Express) + TypeScript
Authentication	OTP-based (Firebase/HSP SMS API)
Database	Neon.tech (PostgreSQL)
Storage	AWS S3 (Simple Storage Service)

AI/ML	Google ML Kit (Client) / OpenAI GPT-3.5 (Backend)
Deployment	Vercel (CI/CD)

---

8. Summary of Security Controls

- **End-to-End Encryption (E2EE):** Data is encrypted at the source and decrypted at the destination.
- **Multi-Factor Auth:** Mobile number verification via OTP.
- **Temporary Access:** Storage URLs expire within minutes.
- **Stateless Server:** The backend stores no clear-text sensitive data or master passwords.
- **Privacy First:** Nominees have zero visibility into the vault until the Legacy Protocol is officially activated.